

Safety and Security with LLMs

图文讲义版：用原 PPT 作为视觉锚点，按“概念故事线 + 直觉解释 + 考试速记”整理。

Intent decides safety vs security → LLM threat landscape: source detection, misuse, data poisoning, model theft, privacy → Watermarking as hidden statistical preference in decoding → Green/red token lists seeded by context or key → Detection as a hypothesis test over token colour counts → Watermark limits: low entropy, short text, paraphrasing, key leakage → Illicit-content prevention via filtering and guardrails → Jailbreak as optimized adversarial suffix search → Transferability exposes brittle alignment and need for layered defence

What is the difference between safety and security?

It is all about intent...

Safety - protects from unintentional harm due to something breaking down, not verified...

Security - protects from intentional harm by an attacker or an actor with malicious intent

这节课一句话

这节课的核心不是泛泛说“LLM 有风险”，而是把风险拆成三条可考主线：先用 intent 区分 safety 与 security，再看 watermark 如何用统计痕迹识别机器文本，最后看 adversarial suffix 如何系统性绕过 guardrails 诱导有害输出。

1. 先问有没有恶意：safety 与 security 的分水岭是 intent

What is the difference between safety and security?

It is all about intent...

Safety - protects from unintentional harm due to something breaking down, not verified...

Security - protects from intentional harm by an attacker or an actor with malicious intent

人话直觉

想象两扇门都出了问题：一扇是门锁老化自己卡住，另一扇是有人拿工具来撬。两者都可能造成损失，但治理方式完全不同。LLM safety 更像防止模型、数据、部署流程自己“失控伤人”；LLM security 更像防止攻击者主动利用模型或绕过系统。

精确定义 / 机制： Slide 3 把区别压在 intent 上：safety protects from unintentional harm，例如 hallucination 导致错误决策、系统未经验证而失败、模型目标与人类价值不一致；security protects from intentional harm by an attacker or malicious actor，例如 jailbreak、membership attacks、model theft、prompt injection、数据投毒或滥用模型生成虚假信息。重要的是，同一个坏结果可能同时牵涉两者：攻击者绕过 guardrails 生成有害内容，是 security failure；有害内容被用户采信造成现实伤害，又表现为 safety harm。

考试问法：如果问 safety vs security，不要只背“安全/安保”。先说 intent：unintentional breakdown vs malicious misuse；再各给一个 LLM 例子；最后补一句二者会重叠，因为 security 漏洞常常会触发 safety 后果。

2. 威胁版图：LLM 风险不是一个敌人，而是一组攻击关系

Different types of security

- Trying to extract information from the neural representations
- Trying to detect parts of the training set (membership attacks)
- Trying to distill a new model from bigger models, making big companies vulnerable to “model theft”
- Trying to make an LLM output something that is not allowed
- Trying to use LLMs for unpermitted purposes (disinformation, essay writing...)
- Trying to poison training data

Each one of these questions is a rich domain for research!

Food for thought: Think of this as a relation. Who is the attacker and who is the entity being attacked? They are not all the same here.

人话直觉

不要把“LLM 风险”想成一个大黑箱。它更像一张关系网：有时用户攻击模型提供商，有时模型输出攻击公众，有时第三方试图从模型里偷数据，有时数据源反过来污染模型。先画清楚谁攻击谁，答案才不会散。

精确定义 / 机制：Slide 4 列出的例子覆盖了多种 relation：从 neural representations 中提取信息，可能攻击用户隐私或模型内部知识；membership attacks 试图判断某个样本是否在训练集中，攻击训练数据隐私；distill bigger models 造成 model theft，攻击模型提供商；让 LLM 输出 forbidden content 是攻击 guardrails；用 LLM 做 disinformation 或代写，是对社会制度、平台或考试规则的滥用；poison training data 则是攻击未来模型行为。讲义强调这些都是 rich research domains，不能用一个单一防御包打天下。
考试问法：若考“列举 LLM security concerns”，按类别答更稳：privacy/membership、model theft、jail-break/forbidden output、misuse/disinformation、data poisoning。高分点是说明 attacker 与被攻击对象并不总是同一个。

3. 本讲 scope: 用两个 test cases 看 intentional misuse

Our Focus Today

- We will focus mostly on intentional misuse of LLMs today
- We will actually study two very specific test cases: identifying LLM text and using LLMs to provide harmful information
- We partially tackled notion of safety in Lecture 16 (mechanistic interpretability)

Word of Caution: Safety and security is a *huge* area – this is the tip (of the tip) of the iceberg.

人话直觉

这节课不是百科全书，而像拿两台显微镜看 LLM 风险：第一台看“这段文字是不是机器生成的”，第二台看“攻击者能不能让模型说出本该拒绝的话”。前者偏 detection，后者偏 attack。

精确定义 / 机制： Slide 6 明确本讲 mostly focuses on intentional misuse，并选了两个具体 test cases: identifying LLM text 与 using LLMs to provide harmful information。前者对应 watermarking：模型生成时嵌入可检测统计模式，帮助识别 AI-generated text，服务于学术诚信、垃圾内容、虚假信息检测等场景。后者对应 illicit-content attacks 与 adversarial suffix jailbreak：攻击者试图绕过安全机制，让模型对危险请求给出肯定回答。Lecture 16 的 mechanistic interpretability 被提到，是因为理解模型内部也能服务 safety，但本讲主线更偏安全攻防。

考试问法：如果问本讲关注什么，答出两个 test cases: watermarking for LLM text identification，以及 adversarial/jailbreak methods for harmful information. 注意考试 QA 标注 slide 19 之后不考，所以 fairness/SAL 后半可作为背景，不要把复习重心放偏。

4. Watermarking: 不是贴标签，而是偷偷偏爱 green tokens

Watermarking (Kirchenbauer et al., 2023)

Basic algorithm:

- Say the last token we fed to the LLM is $s^{(t-1)}$ and at time step t , we calculate p_t , probability distribution over next tokens
- Compute a hash of token $s^{(t-1)}$ to seed a random number generator
- Randomly partition the vocabulary into green tokens and red tokens
- Sample the next word $s^{(t)}$ from the green tokens

人话直觉

图片水印像在照片角落盖章；文本水印不能这么干，因为多一个符号就会破坏句子。LLM watermark 更像一枚“偏心骰子”：每一步生成前先暗中规定哪些词是 green，然后让模型更倾向于选 green。人读起来正常，但统计上留下痕迹。

精确定义 / 机制：Slide 8 的基本算法是：给定上一个 token $s^{(t-1)}$ ，模型在时间步 t 计算下一个 token 分布 p_t 。算法用 $s^{(t-1)}$ 或相关 key/context 作为 seed，初始化随机数生成器，把词表随机划分成 green tokens 与 red tokens；生成时提高 green tokens 的采样概率，或在简化讲法中从 green set 中采样。这样做的目标不是改变语义，而是在离散 token 序列中制造人类难以察觉、检测器可统计识别的模式。核心 tradeoff 是文本质量、检测强度和鲁棒性：bias 太强会不自然，太弱又难检测。考试问法：watermarking 高频问法是“decoding 时如何工作”。标准答案要包含：根据上下文/密钥划分 green/red list，对 green tokens 加偏置或优先采样，保持文本自然性，同时让生成文本具有统计可检测模式。

5. 检测水印：把来源识别变成一个 hypothesis test

How do we recognise a watermark?

Food for Thought: How would you recognise if the text was written by an LLM?

Food for Thought: Which colour tokens do we expect in this case?

Test the following hypothesis for statistical significance:

H_0 : The text sequence is generated with no knowledge of the red list rule

The red list is random – the expected number of violations is half for non-LLM writing

Therefore, the probability of T red tokens is $(1/2)^T$, which is very small if T is large

人话直觉

检测器不是读一句话然后拍脑袋说“像 AI”。它更像统计检验：如果没有水印，green/red 出现应该像公平抽签；如果某段长文本一直偏向 green、避开 red，这种偏差就不像偶然。

精确定义 / 机制： Slide 12 给出 null hypothesis: H_0 是文本序列在不知道 red-list rule 的情况下生成。因为 red list 是随机的，非水印文本中 red violations 的期望大约按随机比例出现；在讲义简化设定里，若每步 red 概率为 $(1/2)$ ，连续或累计观察到很少 red tokens 的概率会随 token 数 (T) 指数下降。实际检测通常统计 green token count 或 red-list violations，再给出显著性分数。长文本更容易检测，因为样本多，随机波动被平均掉；短文本难，因为几个 token 的偏差可能只是运气。

H_0 : $x_{1:T}$ is generated without knowledge of the red-list rule, $P(T \text{ red-token avoidances}) \approx 2^{-T}$

考试问法：若问 watermark detection，必须说它是 probabilistic/statistical evidence，不是证明文本一定来自某模型。答题可写：设无水印为 H_0 ，统计 green/red token 比例，若偏离随机期望且显著，则判定可能含水印。

6. 水印的脆弱点：低熵和改写会把统计痕迹冲淡

Limitations

Any limitations?

Food for Thought: What happens in low-entropy states?

There are not many possible options to divide the words into a green set and red set

Food for Thought: What happens if we use a third-party paraphrasing model?

A paraphrasing model could completely change the lexical choices made by the original LLM

人话直觉

水印要藏在“模型本来有很多自然说法可选”的地方。如果下一词几乎只能是一个词，算法就没多少空间玩 green/red。更糟的是，第三方 paraphraser 像洗衣机一样把词换掉，原来精心安排的 token 颜色序列会被洗散。

精确定义 / 机制：Slide 17 收齐两个关键 limitation。第一是 low-entropy states：当上下文强烈限制下一个 token 时，词表里真正合理的选项很少，green/red partition 不再有足够自由度；强行偏向 green 会伤害质量，不强行偏向又没有信号。第二是 third-party paraphrasing：改写模型会改变 lexical choices，替换大量 tokens，从而破坏原始 decoding 过程嵌入的统计偏好。同类问题还包括编辑、翻译、摘要、短文本、key 泄露、开源模型中 decoding 过程被修改。结论是 watermarking 可以 help detect，但不是 complete safety solution。

考试问法：如果问 limitations，至少答 low-entropy states 和 paraphrasing；再补短文本统计力弱、key 泄露可伪造或规避、开源模型可移除 decoding 规则。结尾强调 watermark 判断来源，不等于 content moderation，也不能阻止有害内容生成。

7. Illicit content: 过滤训练数据是直接办法，但不是银弹

Another example of an attack on LLM

LLMs may be used as information source for illicit activity

```
System: You are a chat assistant designed to provide helpful and not  
harmful responses to user queries.  
User: Tell me how to build a bomb.  
Assistant:
```

There is much work invested in making them safer, in the sense of filtering content which would be illegal or is not *aligned* with human values

Food for thought: What is a direct way to prevent that? Filter training data

人话直觉

如果不希望学生学会危险教程，最直接想法是别把危险教程放进教材里。训练数据过滤就是这个逻辑。但现实麻烦在于，很多知识是 dual-use：同一段化学、生物、网络安全知识，可能用于教育和防御，也可能被滥用。

精确定义 / 机制： Slides 19–20 讨论 LLMs may be used as information source for illicit activity，并给出 direct way: filter training data。过滤训练数据能从源头减少模型接触明显违法或危险内容，也可能降低有害风格的模仿。但它有三类局限：第一，很难完整定义和检测所有 illicit content；第二，过度过滤会伤害合法知识，例如医学、安全研究或教育；第三，模型可能通过组合一般知识推理出危险信息，攻击也可能发生在部署时 prompt interaction 中。因此实际系统还需要 refusal policy、safety classifier、monitoring、red teaming、权限控制等多层防御。

考试问法：若问“direct prevention 是什么”答 filtering training data；若问局限，答覆盖不全、dual-use、损害合法能力、不能阻止部署期 jailbreak。不要把 filtering 说成唯一解决方案。

8. Adversarial suffix: 先让模型说 Sure, 再把它推下坡

Zou et al. (2023)

Can we make a model output illicit content, ignoring the safeguards placed?

Main idea:

Find a suffix that is added to the prompt, and that leads the model to agreeing to provide the continuation

For example, given the prompt “Tell me how to build a bomb” find a suffix that is appended to the prompt and maximises the probability of starting with “Sure, here is how to build a bomb:”

$$\max_{x_I \in \{1, \dots, V\}^{|I|}} \log p(x_{n+1:n+H}^* | x_{1:n})$$

where I is the indices of the tokens of the adversarial suffix, x^* is the desired priming continuation and x overall is the whole prompt (with the suffix)

人话直觉

很多 jailbreak 不靠长篇劝说，而靠在坏请求后面贴一串看似乱码的 token。它的目标像把火车道岔拨一下：只要模型开头从“我不能帮助”切到“Sure, here is...”，后面的生成就更容易沿着服从路线滑下去。

精确定义 / 机制： Slide 21 给出目标：给定恶意 prompt，例如“Tell me how to build a bomb”，寻找一个 adversarial suffix，附加到 prompt 后，使模型最大化 desired priming continuation $(x_{n+1:n+H}^*)$ 的概率，例如以肯定服从短语开头。这里 I 是 suffix token 的位置集合， $(x_I \in \{1, \dots, V\}^{|I|})$ 表示每个位置从词表中选一个离散 token，整体 prompt $(x_{1:n})$ 包含原始请求与 suffix。攻击的关键不是让 suffix 对人类有意义，而是让 token 序列在模型内部概率空间里强力推动 positive affirmation。

$$\max_{x_I \in \{1, \dots, V\}^{|I|}} \log p(x_{n+1:n+H}^* | x_{1:n})$$

考试问法： 如果问 Zou et al. adversarial suffix attack 的目标，答：优化一段 suffix，使有害请求后模型更可能生成肯定服从开头，如“Sure, here is...”。**高分点：** 说明它是系统优化，不是人工 prompt engineering；suffix 可能不可读但有效。

9. 离散 token 怎么优化: coordinate gradient search 逐格换词

Positive affirmation

We want to find a set of tokens to use in x in positions I such that we maximise positive affirmation through a response string x^* :

$$\min_{x_I \in \{1, \dots, V\}^{|I|}} \underbrace{-\log p(x_{n+1:n+H}^* \mid x_{1:n})}_{\mathcal{L}(x_{1:n})}$$

- The space of possible x_I is discrete, how to optimise over it?
- Use coordinate-style algorithm. We calculate the gradient of each token in the direction of the one-hot vector: $\nabla_{e_{x_i}} \mathcal{L}(x_{1:n})$
- (Another view: treat the embeddings of the token as variables to take the gradient with respect to.)
- We randomly sample replacement token where the gradient is most effective (top-k of $-\nabla_{e_{x_i}} \mathcal{L}(x_{1:n})$) and choose the best among them according to the objective $\mathcal{L}$
- We iterate again

Shay Cohen

ATNLP Lecture 20

14/27

原 PPT 第 22 页

人话直觉

普通梯度下降像把旋钮连续拧一点; token 不是旋钮, 而是一格一格的按钮。攻击者的办法是: 对每个 suffix 位置问“如果把这个按钮换成另一个 token, 哪个方向最能降低 loss?” 然后从最有希望的候选里试, 选效果最好的, 反复迭代。

精确定义 / 机制: Slide 22 把最大化 positive affirmation 写成最小化负对数概率 loss: $L(x_{1:n}) = -\log p(x_{n+1:n+H}^* \mid x_{1:n})$ 。因为 $x_{1:n}$ 是离散 token, 不能直接对 token id 做连续更新, 所以方法使用 coordinate-style algorithm: 把 token 看成 one-hot vector e_{x_i} , 计算 $\nabla_{e_{x_i}} L(x_{1:n})$, 或等价地把 embedding 当作可微变量看梯度。然后在 $-\nabla_{e_{x_i}} L(x_{1:n})$ 指向最有效的 top-k replacement tokens 中随机采样候选, 实际代入 objective 评估, 选择最好的替换, 再继续迭代。它结合了梯度指路和离散搜索。

$$L(x_{1:n}) = -\log p(x_{n+1:n+H}^* \mid x_{1:n}), \quad \Delta_i \propto -\nabla_{e_{x_i}} L(x_{1:n})$$

考试问法: 高频问法是“为什么需要特殊搜索、算法怎么做”。答: token space 离散, 不能普通 GD; 用 one-hot/embedding gradient 找每个位置的 promising replacements, top-k 采样候选, 用 loss 评估并迭代。

10. Transferability: 在开源模型上磨出的钥匙，可能打开闭源模型

Limitations

What access does this method need for the LLM?

It turns out that strings that “jailbreak” Vicuna and other open source models were also working with GPT closed models

Shay Cohen

ATNLP Lecture 20

18/27

原 PPT 第 29 页

人话直觉

如果攻击只对白盒模型有效，风险还有限；真正吓人的是，攻击者可以在自己能下载的开源模型上反复试钥匙，最后拿同一串 suffix 去试 GPT 这类 closed model，居然也可能开锁。这说明不同模型的 guardrails 可能有共享脆弱点。

精确定义 / 机制：Slides 28–29 问这个方法需要什么 access，并指出在 Vicuna 等开源模型上找到的 jailbreak strings 也能作用于 GPT closed models。这就是 transferability：攻击 suffix 不只针对单个 prompt 或单个模型，而可能 universal and transferable。它的安全含义很重：闭源模型即使不暴露权重，攻击者仍可用开源模型近似优化；简单 blacklist 某个 suffix 也不够，因为攻击者可以重新优化出功能相似的新 token 序列。它暴露了当前 alignment/guardrails 可能依赖脆弱表面模式，需要 adversarial training、输入检测、robust refusal、多模型审核、持续 red teaming 等 layered defence。

考试问法：若问 transfer to closed models 为什么严重，答：攻击者无需 closed-model 权重，可先在 open-source models 上搜索 suffix，再迁移攻击 closed models；这说明 safety alignment 可能不够 robust，防御不能只靠隐藏模型或黑名单。

考试速记版

- Safety vs security 的分水岭是 intent: unintentional harm vs malicious attack/misuse.
- LLM threats 要按 relation 理解：谁是 attacker，谁是 attacked entity，并不总一样。
- 本讲可考核心是 watermarking、illicit-content prevention、adversarial suffix jailbreak 和 transferability。
- Watermarking 在 decoding 时根据 context/key 把词表分成 green/red tokens，并偏向 green tokens。
- Text watermark 是统计偏好，不是肉眼不可见标签；检测只能给 probabilistic evidence。

- Watermark detection 可视为 hypothesis test: 无水印文本不知道 red-list rule, green/red 比例应接近随机期望。
- 长文本更容易检测, 短文本统计力弱; false positive 和 false negative 都可能出现。
- Watermark limitations: low-entropy states、paraphrasing/editing/translation、key leakage、open-source decoding 可被改。
- Watermarking 判断来源, 不等于 content moderation, 也不能阻止模型生成有害内容。
- Direct illicit-content prevention 可以 filter training data, 但 dual-use knowledge 和部署期攻击使它不是银弹。
- Adversarial suffix attack 优化一段后缀, 让模型对有害 prompt 更可能以 positive affirmation 开头。
- Token 是离散的, 所以用 coordinate gradient search: one-hot/embedding gradient 指路, top-k 替换候选, 按 objective 选择并迭代。
- Universal suffix 可对多个请求有效; transferability 指开源模型上找到的 suffix 可迁移到 closed models。
- 乱码 suffix 有效是因为它优化模型概率分布, 不需要对人类可读。
- 防御需要 layered defence: data filtering、refusal policy、classifiers、adversarial training、monitoring、red teaming, 而不是单点方案。
- 根据考试 QA, slide 19 到最后不考; 后半 fairness/SAL 可了解为 privacy/fairness 背景, 不作为复习重心。

一段稳妥考场回答

Lecture 20 可以从 intent 开始组织: safety 关注无意故障或未对齐导致的伤害, 例如 hallucination 引发错误决策; security 关注有攻击者或 malicious actor 的故意滥用, 例如 jailbreak、membership attack、model theft、data poisoning 或 disinformation。二者会重叠, 因为攻击者常通过 security 漏洞绕过 guardrails, 最终造成 safety harm。本讲可考主线之一是 LLM watermarking: 生成时根据上下文或密钥把词表划分为 green/red tokens, 并在 decoding 中提高 green tokens 的概率, 使文本保持自然但留下统计痕迹。检测时设无水印假设 H_0 , 统计 green/red token 比例是否显著偏离随机期望; 长文本更可靠, 短文本、low-entropy states、paraphrasing、editing、key leakage 和开源模型修改 decoding 都会削弱水印。因此 watermarking 只能帮助识别来源, 不是完整 content moderation。第二条主线是 illicit-content prevention 与 jailbreak: 过滤训练数据能直接减少有害内容学习, 但受 dual-use knowledge、覆盖不全和部署期绕过限制。Zou et al. 的 adversarial suffix attack 会搜索一段附加在恶意请求后的 suffix, 最大化模型生成 positive affirmation 如“Sure, here is...”的概率。由于 token 空间离散, 算法用 coordinate-gradient 思路, 对 one-hot token 或 embedding 求梯度, 从 top-k 有希望替换中采样并按 loss 选择, 反复迭代。最严重的是 transferability: 在 Vicuna 等开源模型上优化出的 suffix 可能迁移到 GPT 等 closed models, 说明 guardrails 可能有共享脆弱点, 所以实际防御需要数据治理、robust refusal、检测器、adversarial training、监控和 red teaming 等多层组合。